

CISSP Printable Practice Exam 31 - Domain 7 - Security Operations

Practice Exam 04 - Domain 7

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP4-117)

Scenario: A regional airline's internal security team has imaged several servers after detecting unauthorized access to crew scheduling data. Outside counsel has engaged an external digital forensics firm to complete the analysis, and the imaged drives must now leave the airline's custody.

What should the security team do BEFORE releasing the evidence to the external firm?

- A. Document the transfer with signed custody records, verification hashes, and a description of handling conditions
- B. Send the drives by standard mail without recording who packaged or received them
- C. Allow the forensics firm to begin analysis before any transfer documentation is completed
- D. Retain only a summary of findings and discard the original images once copies are made

Question 2 (CISSP4-118)

Scenario: A semiconductor manufacturer's forensic analyst has completed a full disk image of a workstation involved in a suspected intellectual property theft. Before beginning analysis, the analyst must confirm the image accurately represents the original drive.

What should the analyst do to confirm the image's integrity?

- A. Compare cryptographic hash values calculated from the source drive and the acquired image
- B. Open several files on the image and visually confirm they look correct
- C. Assume integrity because the imaging software did not report an error
- D. Recalculate the drive's file count and compare it to the image's file count

Question 3 (CISSP4-119)

Scenario: A metropolitan transit authority is investigating unusual activity tied to a systems administrator's privileged account. The same administrators who manage the affected servers currently have full read, write, and delete access to the central log repository.

Which THREE controls would MOST effectively reduce the risk that logs relevant to this investigation could be altered or destroyed? Select 3 of the 5 options below.

- A. Restrict write and delete access on the central log repository to a team independent of server administration
- B. Grant the administrator under investigation temporary log-management rights to assist with the review
- C. Forward logs in near real time to a separately controlled repository outside the administrators' reach
- D. Apply integrity controls, such as hashing or write-once storage, so past entries cannot be silently altered
- E. Merge log administration into the same role as server administration to simplify support

Question 4 (CISSP4-120)

Scenario: An automotive parts manufacturer repeatedly finds that production servers accumulate undocumented configuration changes between deployments, despite an established

baseline. Engineering is redesigning the deployment process for a new application tier.

Which approach would MOST directly eliminate the opportunity for undocumented configuration drift?

- A. Continue in-place patching and rely on more frequent manual configuration audits
- B. Deploy servers from a version-controlled golden image and replace, rather than modify, instances when updates are needed
- C. Grant additional administrators standing access so changes can be applied faster
- D. Extend the interval between configuration audits to reduce administrative workload

Question 5 (CISSP4-121)

Scenario: An investment bank's identity team is provisioning system access for a newly hired trade settlement analyst. The standard onboarding template for the settlement department includes access to several systems the new analyst's specific duties will not require.

What should the identity team do?

- A. Grant the full departmental template so the analyst never has to request additional access later
- B. Provision only the access required for the analyst's specific assigned duties, adding more only if justified later
- C. Delay provisioning any access until the analyst has worked in the role for several months
- D. Copy the exact access profile of the most senior analyst on the team

Question 6 (CISSP4-122)

Scenario: A grocery retail chain's asset inventory shows that several point-of-sale servers have reached the end of their supported life and are scheduled for replacement next quarter. The servers currently continue to process daily transaction data.

What should the asset management process require before the servers are removed from service?

- A. Confirm data migration or backup, verify successor systems are ready, and schedule sanitization or destruction of the retired hardware
- B. Power off the servers immediately once the replacement date arrives, regardless of data status
- C. Leave the retired servers connected as an informal backup with no further tracking
- D. Transfer the servers to another department without updating asset or data-handling records

Question 7 (CISSP4-123)

Scenario: A telecommunications carrier's security operations center receives three alerts within minutes of each other: an employee-reported phishing email, indicators of active data exfiltration from a customer billing server, and a spike in failed logins on a test system that was decommissioned months ago.

Which THREE practices should the team apply when triaging these alerts? Select 3 of the 5 options below.

- A. Rank the alerts using business impact, asset criticality, and evidence of active compromise
- B. Investigate each alert strictly in the order it arrived, regardless of apparent severity
- C. Escalate the exfiltration indicator immediately while queuing the lower-risk items for scheduled review

- D. Close alerts that lack an obvious technical indicator without recording the reasoning
- E. Document the triage decisions and supporting rationale for later review

Question 8 (CISSP4-124)

Scenario: A pharmacy chain's field auditor reports that a company-issued removable drive containing patient prescription records is missing after a site visit. The drive was provisioned with full-disk encryption, and the encryption key was never stored with the device.

How should the security team approach this event?

- A. Treat it identically to loss of unencrypted data, since any missing device is automatically reportable regardless of controls
- B. Assume no risk exists and close the matter without further review because the drive was encrypted
- C. Investigate the encryption configuration and key management, then determine reporting obligations based on the confirmed control effectiveness
- D. Wait to see whether the data appears publicly before taking any action

Question 9 (CISSP4-125)

Scenario: An aerospace parts manufacturer's firewall rule base has grown over several years with rules added for projects that have since ended. A recent review finds multiple broad rules with no documented owner or current business justification.

What should the security team do with the unjustified broad rules?

- A. Leave the rules in place in case a project resumes at an undetermined future date
- B. Validate current business need with rule owners, then remove or narrow rules that are no longer justified
- C. Widen the rules further so future projects will not require new firewall requests
- D. Disable the entire firewall rule base and rebuild it during the next scheduled outage window

Question 10 (CISSP4-126)

Scenario: An online gaming platform's signature-based anti-malware tool did not flag a workstation later found to be communicating with a known malicious infrastructure address. Endpoint detection and response tooling is available but not yet configured for this workstation class.

What is the BEST way to address this detection gap?

- A. Rely solely on periodic signature updates and wait for vendor coverage to improve
- B. Extend behavioral endpoint detection and response coverage to this workstation class and investigate the affected host
- C. Remove anti-malware tooling from this workstation class since it did not detect the activity
- D. Disable outbound network access for all workstations of this class indefinitely

Question 11 (CISSP4-127)

Scenario: A pediatric specialty clinic network's IT team receives a routine vendor security patch for its electronic health record application. The patch has not yet been evaluated against the clinic's specific configuration.

What should the team do BEFORE deploying the patch to all production systems?

- A. Apply the patch to all systems simultaneously to close the vulnerability as quickly

as possible

- B. Test the patch in a representative non-production environment and confirm compatibility before broader deployment
- C. Skip testing because the vendor has already validated the patch internally
- D. Delay the patch indefinitely until the next major version upgrade

Question 12 (CISSP4-128)

Scenario: A public library system's change management program allows certain well-understood, low-risk, repeatable changes to follow a lighter pre-approved process rather than full change advisory board review. IT staff are unsure whether a routine, previously validated configuration update qualifies.

Which characteristic BEST qualifies a change for the pre-approved standard change process?

- A. The change is well understood, low risk, follows a documented and previously validated procedure, and has a known rollback method
- B. The change has never been performed before but appears simple to implement
- C. The change affects a critical system, so expedited handling is appropriate regardless of documentation
- D. The requester is confident the change will not cause any problems

Question 13 (CISSP4-129)

Scenario: A national parcel shipping company must restore its package-routing system within a small number of minutes after losing its primary data center. The organization can accept installing and starting pre-configured, ready standby equipment but cannot tolerate the cost of continuously mirrored, real-time synchronized processing.

Which recovery site BEST fits this requirement?

- A. A cold site with space and utilities but no installed processing equipment
- B. A warm site requiring several hours of configuration and data restoration
- C. A hot site with installed, largely configured systems that can be brought into service within minutes
- D. A mirrored site with continuous real-time synchronization and immediate failover

Question 14 (CISSP4-130)

Scenario: An agricultural cooperative's nightly backup window has become too short for a full backup of its growing inventory and shipment database, and available backup storage is limited. Management wants backups to complete reliably within the window without exceeding storage capacity.

Which approach would BEST address the described constraint?

- A. Continue full backups every night regardless of the time and storage required
- B. Combine periodic full backups with more frequent incremental or differential backups between them
- C. Stop backing up the database until additional storage budget is approved
- D. Back up the database only once a month to reduce storage consumption

Question 15 (CISSP4-131)

Scenario: An online brokerage platform currently runs its order-entry application on a single server. A hardware or software failure on that server currently takes the entire order-entry function offline until a replacement is brought up manually.

How should the platform improve the availability of the order-entry function?

- A. Deploy the application across a load-balanced cluster of servers so a single

- failure does not remove the service
- B. Increase the memory allocated to the existing single server
- C. Move the application to a different single server with newer hardware
- D. Schedule more frequent manual health checks on the existing server

Question 16 (CISSP4-132)

Scenario: A regional airport authority is conducting the first review of a newly drafted disaster recovery plan. Each plan owner is asked to individually read their assigned sections and confirm they are accurate and current, without any group discussion or system activity.

Which TWO characteristics describe this type of disaster recovery test? Select 2 of the 5 options below.

- A. Each plan owner independently reviews their assigned sections for accuracy and currency
- B. Cross-functional teams gather to discuss the plan and talk through a sample scenario together
- C. No recovery systems or production services are activated at any point during the review
- D. Recovered systems operate in parallel with production so results can be compared
- E. Completing this review alone satisfies the organization's requirement for a full interruption test

Question 17 (CISSP4-133)

Scenario: A ride-sharing company is beginning formal business continuity planning for the first time. Leadership has drafted a recovery strategy based on which systems the technology team believes are most important, without input from the business units that depend on them.

What should the organization do BEFORE finalizing recovery priorities?

- A. Conduct a business impact analysis with business units to identify critical processes, dependencies, and recovery objectives
- B. Finalize the plan as drafted since the technology team understands the systems best
- C. Set identical recovery time objectives for every system to avoid the analysis effort
- D. Wait until after the next actual disruption to learn which systems matter most

Question 18 (CISSP4-134)

Scenario: A colocation data center provider is finalizing fire protection for a new equipment room housing customer servers and storage arrays. Water-based suppression could protect the building structure but risks damaging the electronic equipment it is meant to save.

Which approach BEST balances equipment protection and personnel safety in this environment?

- A. Install a clean-agent suppression system suited to electronic equipment, supported by appropriate detection and evacuation procedures
- B. Rely on a standard water sprinkler system because it is the least expensive option
- C. Install no fire suppression system to avoid any risk of equipment damage
- D. Use a suppression agent chosen without regard to occupant safety during discharge

Question 19 (CISSP4-135)

Scenario: A large K-12 school district currently relies on individual office staff making phone calls to notify each school during an emergency. A recent drill showed that some schools received notification many minutes after others, delaying protective actions.

What should the district implement to improve emergency communication?

- A. A mass notification system that can reach all schools simultaneously through multiple channels
- B. A requirement that only the superintendent's office may originate any emergency call
- C. A single shared phone line that each school must call in sequence to receive updates
- D. A policy directing schools to wait for a printed bulletin before taking protective action

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP4-117) - Correct: A

A documented, signed transfer with verification hashes and handling details preserves the chain of custody and supports the evidence's later admissibility and credibility. Unrecorded shipping breaks the custody record needed to show the evidence was not altered. Beginning analysis before documentation creates gaps in accountability, and discarding original images removes the authoritative source that verification depends on.

Question 2 (CISSP4-118) - Correct: A

Matching cryptographic hash values computed from the source and the image provide strong, verifiable evidence that the copy is bit-for-bit identical to the original. Visual inspection of a few files does not confirm the entire image. Absence of a software error message does not by itself prove integrity, and comparing file counts can miss subtle alteration that leaves the count unchanged.

Question 3 (CISSP4-119) - Correct: A, C, D

Restricting log-repository control to an independent team, forwarding logs promptly to a separately controlled destination, and applying integrity protections together reduce a privileged administrator's ability to alter evidence of their own actions. Granting the investigated administrator additional log access creates a direct conflict of interest. Merging the two roles removes the separation the investigation depends on.

Question 4 (CISSP4-120) - Correct: B

Replacing instances built from a version-controlled golden image, rather than modifying servers in place, removes the opportunity for undocumented changes to accumulate between deployments. Continuing in-place patching preserves the same drift risk regardless of audit frequency. Additional standing administrative access increases the number of people who can introduce undocumented changes, and a longer audit interval only delays detection rather than preventing drift.

Question 5 (CISSP4-121) - Correct: B

Least privilege calls for provisioning only the access the new analyst's actual duties require, with additional access added later if a specific, justified need arises. Granting the full template regardless of need creates unnecessary exposure. Withholding all access delays legitimate work, and copying a senior analyst's profile typically grants far more access than a new hire's duties warrant.

Question 6 (CISSP4-122) - Correct: A

A controlled decommissioning process confirms that data has been migrated or preserved, that replacement systems are ready to take over processing, and that retired hardware is sanitized or destroyed according to its data sensitivity. Powering off servers without confirming data status risks loss of unprocessed transactions. Leaving retired systems connected without tracking, or transferring them without updated records, both undermine asset accountability.

Question 7 (CISSP4-123) - Correct: A, C, E

Risk-based ranking, immediate escalation of the highest-impact indicator, and documented triage decisions together support a defensible and effective response when multiple alerts compete for attention. Strict arrival-order handling could delay response to the active exfiltration. Closing alerts without recorded justification removes the ability to review or revisit a triage decision later.

Question 8 (CISSP4-124) - Correct: C

The appropriate response confirms whether the encryption was properly configured and the key remained protected, since verified strong encryption can materially reduce or eliminate breach notification obligations depending on applicable requirements. Treating every loss identically ignores the risk-reducing effect of verified encryption. Assuming safety without verification is premature, and waiting for public exposure abandons timely incident handling.

Question 9 (CISSP4-125) - Correct: B

Validating current need with accountable owners and then removing or narrowing unjustified rules keeps the rule base aligned with actual business requirements and reduces unnecessary exposure. Leaving speculative rules in place preserves avoidable risk. Widening rules further increases exposure, and disabling the entire rule base is disruptive and unnecessary when a targeted review can address the specific stale entries.

Question 10 (CISSP4-126) - Correct: B

Extending behavioral endpoint detection and response coverage addresses threats that signature-based tools miss, while investigating the affected host determines the scope of this specific compromise. Waiting on signature updates alone leaves the same detection gap unaddressed. Removing the existing tool eliminates a layer that still has value, and an indefinite blanket network restriction is disproportionate to a targeted detection gap.

Question 11 (CISSP4-127) - Correct: B

Testing the patch in a representative non-production environment confirms compatibility with the clinic's specific configuration before it reaches every production system, reducing the risk of unexpected disruption. Deploying everywhere at once skips that verification. Vendor testing does not account for site-specific configurations, and indefinite delay leaves a known vulnerability unaddressed longer than necessary.

Question 12 (CISSP4-128) - Correct: A

A pre-approved standard change is one that is well understood, low risk, follows a documented and previously validated procedure, and has a known way to reverse it if needed. An unperformed change lacks the track record standard classification requires. Criticality alone does not justify skipping appropriate review, and a requester's confidence is not a substitute for documented, validated criteria.

Question 13 (CISSP4-129) - Correct: C

A hot site provides installed, largely configured systems that can be activated within minutes, meeting a stringent recovery time objective without the continuous synchronization cost of a mirrored site. A cold site requires far more time to become operational. A warm site's multi-hour restoration window does not meet a near-immediate requirement, and a mirrored site exceeds both the stated need and the accepted budget.

Question 14 (CISSP4-130) - Correct: B

Combining periodic full backups with more frequent incremental or differential backups reduces the time and storage each nightly job requires while still supporting restoration to a recent point. Continuing nightly full backups preserves the same window and storage pressure. Suspending backups leaves data unprotected, and monthly-only backups would allow far more data loss than the organization likely intends.

Question 15 (CISSP4-131) - Correct: A

A load-balanced cluster removes the single point of failure by distributing the order-entry function across multiple servers, so one failure does not take the service offline. Adding

memory or moving to newer hardware still leaves a single point of failure. More frequent manual health checks can shorten detection time but do not prevent an outage when the sole server fails.

Question 16 (CISSP4-132) - Correct: A, C

A read-through test involves individual review of the plan for accuracy and currency, with no systems activated and no group exercise conducted. Group discussion of a sample scenario describes a walkthrough rather than a read-through. Parallel operation of recovered systems describes a different, more advanced test type, and an individual read-through does not substitute for the operational assurance a full interruption test provides.

Question 17 (CISSP4-133) - Correct: A

A business impact analysis conducted with the business units that depend on each process produces defensible, evidence-based recovery priorities and objectives, rather than assumptions made by the technology team alone. Finalizing the draft without that input risks misaligned priorities. Treating every system as equally critical ignores real differences in impact, and waiting for an actual disruption forfeits the chance to plan proactively.

Question 18 (CISSP4-134) - Correct: A

A clean-agent suppression system is designed to control fire in equipment-dense environments while limiting damage to electronics, and pairing it with proper detection and evacuation procedures addresses personnel safety. Standard water sprinklers risk significant equipment damage. Omitting suppression entirely leaves both life safety and equipment at risk, and selecting an agent without regard to occupant safety during discharge disregards a core requirement of the decision.

Question 19 (CISSP4-135) - Correct: A

A mass notification system that reaches all schools simultaneously through multiple channels closes the timing gap that sequential manual calling creates. Centralizing origination in one office does not by itself solve the delay in reaching recipients. A single shared line that each school must call in sequence recreates the same delay, and waiting for a printed bulletin is far too slow for protective action during an emergency.